

Tab 1

Fraud Signal Sharing Service (FS3)

POC: Adam Grandt-Nesher - F20D

1. Problem Statement

1.1 Background

Federal agencies independently detect and investigate fraud across a wide range of government programs: benefits, loans, grants, tax, procurement, healthcare, and more. Each agency maintains its own records, case systems, and fraud detection tooling. When a fraudulent actor targets multiple programs simultaneously (a common pattern in sophisticated fraud schemes), no reliable mechanism exists for agencies to share what they know with one another in a timely, structured, or privacy-safe way.

1.2 The Core Problem

Fraud is cross-agency while detection is siloed.

A person who commits identity fraud with SSA, applies for an ineligible SBA loan, and files a fraudulent HUD housing application may be flagged independently by each agency, but those flags never connect. The result:

- Each agency re-investigates from scratch, wasting resources
- The fraudulent actor continues operating across programs until each agency independently reaches a conclusion
- No agency benefits from the corroborating signal that other agencies already hold
- Cases that would be open-and-shut with corroboration remain inconclusive in isolation

1.3 The Privacy Barrier

The obvious solution, agencies sharing subject data with one another, is not viable. Sharing raw personally identifiable information (PII) such as Social Security Numbers, names, or taxpayer IDs across agency boundaries raises significant legal, policy, and security concerns:

- Legal constraints: Agencies are bound by the Privacy Act, program-specific statutes, and data use agreements that restrict how subject data may be shared
- Security risk: Centralizing raw PII creates high-value targets for breaches
- Attribution sensitivity: An agency may not want its fraud flags visible to other agencies, as premature disclosure could compromise ongoing investigations

1.4 The Gap

There is currently no shared infrastructure that allows agencies to:

- Signal that a subject is under fraud suspicion without transmitting that subject's PII

- Discover that another agency has flagged the same subject without a central PII store
- Receive timely, corroborated intelligence when multiple agencies have flagged the same actor
- Control how their signals are attributed and disseminated

2. Imagined Solution

2.1 Vision

The Fraud Signal Sharing Service (FS3) is a GSA-operated inter-agency platform that enables federal agencies to share fraud intelligence in a structured, privacy-preserving, and controlled way. Agencies contribute fraud signals (not case files, PII, or investigative narratives) and in return receive corroborated alerts when the same subject appears across multiple agencies.

2.2 The Privacy-Preserving Matching Model

The central technical innovation is identifier hashing. Instead of transmitting a subject's SSN, name, or TIN, the reporting agency computes a keyed HMAC-SHA-256 digest of the identifier using a shared secret key managed by GSA:

None

```
digest = HMAC-SHA-256(key, canonicalize("123-45-6789"))
      = "9f2c1a4be0d3f5c6a7b8e9d0c1b2a3f4..."
```

- The digest is meaningless without the key — it cannot be reversed to recover the SSN
- The same SSN, hashed with the same key, always produces the same digest
- Two agencies that independently hash the same SSN will produce matching digests
- GSA can detect the match without ever seeing the underlying SSN

This means correlation without exposure: GSA learns that two agencies flagged the same subject; neither agency learns the other's raw data; and no plaintext PII exists anywhere in the system.

2.3 Two-Direction Information Flow

FS3 operates on two distinct flows:

Reports (Agency → GSA)

An agency submits a structured fraud report containing: the subject's hashed identifiers, a fraud category, a signal type, a confidence score, and a severity level. Reports are agency-owned (only the submitting agency and GSA can see them).

Alerts (GSA → Agencies)

When GSA detects that two or more agencies have reported on the same subject, it issues a curated alert. Alerts are minimized: they contain corroboration metadata (how many agencies, over what time range) and signal type aggregations, but do not expose which agencies reported or what their reports contained (unless those agencies have explicitly permitted attribution).

2.4 Key Design Principles

Principle	Expression in FS3
PII never in the clear	All sensitive identifiers transmitted as HMAC digests only
Digests never in URLs	Identifier-based lookups always use POST request bodies
Agency controls attribution	Sharing preference governs whether GSA may name the agency in an alert
Append-only audit trail	Reports are never deleted; retractions are lifecycle events
Corroboration drives alerts	A single report does not trigger an alert; cross-agency matching does
Extensibility without versioning	Signal types are registry-governed, not hard-coded in the API

2.5 What FS3 Is Not

- Not a case management system. FS3 exchanges signals, not investigation records.
 - Not a PII database. No plaintext identifiers are stored or transmitted.
 - Not a real-time verification service. FS3 is asynchronous intelligence sharing, not identity proofing.
 - Not authoritative. An FS3 alert is corroborating intelligence, not a determination of guilt or ineligibility.
-

3. Proof of Concept Requirements

The PoC must demonstrate the core value proposition — cross-agency fraud correlation without PII exchange — in a way that is understandable to a non-technical audience in a live demo.

3.1 Must-Have (Core Demo)

FR-1: Report Submission

- An authenticated agency user can submit a fraud report
- The report includes: a subject identifier (e.g., SSN), fraud category, signal type, confidence, and severity
- The identifier is hashed client-side before transmission; the raw value is never sent
- The UI visibly shows the transformation: plaintext input → HMAC digest → API payload
- The server stores the hashed report and returns a report ID

FR-2: Cross-Agency Matching and Alert Generation

- When a second agency submits a report whose subject identifier hashes to the same digest as an existing report, the system automatically detects the match
- A corroborated alert is minted and stored
- The alert captures: subject digest(s), primary category, contributing signal types, severity, corroboration metadata (report count, agency count, date range)
- No raw PII or individual report contents are exposed in the alert

FR-3: Alert Search

- An agency can search for alerts by submitting one or more hashed identifiers
- The search returns all matching alerts the agency is entitled to see
- If no alert matches, an empty result is returned (not an error)
- The identifier is hashed client-side before the search request is sent

FR-4: Alert Retrieval

- An agency can retrieve a single alert by its alert ID
- The alert view shows corroboration metadata but does not expose contributing agencies (unless all permitted attribution)

FR-5: Webhook Notification

- Subscribed agency endpoints receive a webhook POST when a new alert is issued
- The webhook payload contains the full alert object
- The demo UI includes a live "webhook log" showing received events in real time

FR-6: Multi-Agency Simulation

- The UI supports switching between at least three simulated agency contexts (e.g., SSA, SBA, HUD) to demonstrate independent submission and corroboration
- Each agency context is isolated: Agency A cannot see Agency B's raw reports

3.2 Should-Have (Stretch Goals)

FR-7: Report Retraction

- An agency can retract one of its own reports
- Retraction is an append-only event; the report is not deleted
- If retraction reduces corroboration below the alert threshold, the alert status updates to `withdrawn` and subscribers are notified

FR-8: GSA Dashboard

- A GSA-privileged view shows all alerts, corroboration levels, and contributing signal type distributions
- Provides a sense of the "GSA curator" role described in the spec

FR-9: Tamper Demonstration

- The UI includes a mode that shows what happens when an identifier is altered by one character — the digest changes entirely and no match is found
- Illustrates the integrity property of HMAC hashing

3.3 Out of Scope for PoC

The following spec features are explicitly excluded from the PoC to keep scope manageable:

Feature	Reason Excluded
OAuth 2.0 client credentials	Replaced by simple per-agency API key or header
HMAC key rotation / key metadata endpoint	Single hardcoded key (<code>demo-key-1</code>)
Taxonomy registry validation	Signal types accepted as free-form <code>namespace:type</code> strings
PII narrative screening (NER)	<code>narrative</code> field omitted entirely
Sharing preferences / dissemination entitlements	All agencies see all alerts
Cursor-based pagination	All results returned in a single response
RFC 9457 Problem Details	Simplified <code>{ "error": "message" }</code> responses
Webhook HMAC signature verification	Skipped for demo simplicity
Idempotency keys	Not implemented
Secondary categories	Primary category only

To do

To do

- Work on the form
- Backend team to work on the matching data collection
- Hashing
- Sharing
- Notification

Resources:

<https://chat.gsa.usai.gov/s/fda3590e-6af9-4999-add7-ddd110a6ae70>